

Vulnerability Assessment Report of Findings

MetaBananaCat S.r.l.

NemiSec

Emy Mangogna – emanuela.mangogna@gmail.com

20/9/2025

Table of contents

Engagement Contacts.....	p2
Executive Summary.....	p2
○ Approach.....	p2
○ Scope.....	p3
○ Assessment overview & recommendations.....	p4
Vulnerability Assessment Summary.....	p5
○ Summary of findings.....	p5
Remediation Summary.....	p6

Engagement Contacts

MetaBananaCat Contacts		
Primary Contact	Title	Primary Contact Email
Mr FlyffyChonk	Chief Executive Officer	chonk@miao.com
Secondary Contact	Title	Secondary Contact Email
Mr Wiskerpuff	Chief Technical Officer	purrrpurrr@miao.com

Assessor Contacts		
Assessor Name	Title	Email
Emy Mangogna	Security Consultant	emanuela.mangogna@gmail.com

Executive Summary

Questo report presenta i risultati di una Vulnerability Assessment condotta per **MetaBanana S.r.l.** con l'obiettivo di identificare e valutare le vulnerabilità presenti nei sistemi e servizi interni, verificando la sicurezza delle comunicazioni crittografate, dei servizi di accesso remoto e delle applicazioni web. La valutazione include test di configurazione, analisi di software obsoleto e verifica di chiavi e certificati crittografici, con l'obiettivo di fornire una panoramica chiara dei rischi e indicazioni per mitigare eventuali compromissioni.

Approach

L'assessment è stato condotto utilizzando **Nessus** come motore di vulnerability scanning. La metodologia ha incluso:

- **Port scanning e service enumeration** per identificare porte TCP aperte e i servizi associati.
- **Banner grabbing** e fingerprinting dei servizi per determinare le versioni software in uso.
- **Correlation con database CVE** e plug-in Nessus per rilevare vulnerabilità note.
- **Verification manuale parziale** per confermare la presenza effettiva di alcune misconfigurazioni (es. debolezza VNC, servizi SSL obsoleti, bind shell attiva).

Non sono state condotte attività di exploitation distruttivo, privilege escalation o persistence, ma solo attività di vulnerability assessment in modalità non intrusiva.

Scope

L'attività ha riguardato l'analisi dell'host interno appartenente al dominio di test **MetaBanana**, identificato come target per il Vulnerability Assessment. L'analisi ha incluso tutti i servizi esposti su porte TCP rilevate, in particolare:

- **SSH (22)**
- **SMTP (25)**
- **PostgreSQL (5432)**
- **Bind shell (1524)**
- **VNC (5900)**
- **Apache Tomcat AJP (8009)**
- **HTTP (80)**

Sono stati esclusi dallo scope: attività di social engineering, physical penetration e attività su altri segmenti di rete non specificamente autorizzati.

Asset In-Scope:

Host/IP Address	Description
192.168.50.101	Server interno MetaBananaCat

Tipo di test: black-box interno — nessuna credenziale fornita; attività svolte da un account non autenticato sulla rete interna.

Limitazioni e vincoli: esclusione di attività intrusive o distruttive su sistemi di produzione; nessuna modifica persistente apportata agli host target;

Assessment Overview and Recommendations

L'assessment ha evidenziato un numero significativo di vulnerabilità ad alta severità. Le problematiche principali riguardano l'utilizzo di protocolli crittografici obsoleti (SSLv2/SSLv3) e suite deboli soggette ad attacchi noti come SWEET32, oltre a debolezze critiche nella generazione delle chiavi OpenSSL/OpenSSH che rendono prevedibili le comunicazioni cifrate.

Sono stati rilevati servizi remoti non protetti, come un server VNC configurato con password predefinita, e componenti applicativi vulnerabili come Apache Tomcat (Ghostcat) che permettono accesso non autorizzato ai file e potenziale esecuzione di codice.

Infine, l'ambiente si basa su un sistema operativo obsoleto (Ubuntu 8.04 EoL), non più supportato con patch di sicurezza, e presenta configurazioni di rete insicure come condivisioni NFS world-readable e un servizio BIND esposto a downgrade o attacchi di tipo Denial of Service.

Main recommendations:

- **Isolare e bonificare** i sistemi compromessi (backdoor rilevate).
- **Aggiornare** OS e software obsoleti (Ubuntu 8.04, OpenSSL/OpenSSH, Tomcat, BIND).
- **Disabilitare protocolli e cifrari deprecati** (SSLv2/SSLv3, 3DES/Blowfish).
- **Rigenerare chiavi crittografiche** dopo l'aggiornamento OpenSSL/OpenSSH.
- **Rimuovere credenziali di default** (es. VNC "password").
- **Limitare accessi e permessi** su NFS e servizi di rete esposti.
- **Applicare hardening** dei servizi e controlli firewall per ridurre la superficie di attacco.

La priorità di intervento è **molto elevata**, poiché diverse vulnerabilità critiche consentono accesso remoto non autenticato, compromissione delle comunicazioni cifrate e potenziale esfiltrazione di dati sensibili. L'immediata applicazione delle contromisure è essenziale per contenere il rischio e migliorare la resilienza complessiva dell'infrastruttura.

Vulnerability Assessment Summary

L'assessment sull'infrastruttura di **MetaBanana** ha rilevato **10 vulnerabilità**, con prevalenza di criticità elevate. I principali rischi identificati riguardano protocolli SSL/TLS obsoleti, chiavi crittografiche prevedibili, servizi remoti non autenticati e software non aggiornato, che potrebbero consentire attacchi di tipo MITM, accesso non autorizzato e compromissione completa dei sistemi.

Summary of Findings

PLUGIN ID	SEVERITY	CVSS V3.0	NAME	DESCRIPTION
51988	CRITICAL	9.8	Bind Shell Backdoor Detection	Rileva la presenza di una shell di bind, potenziale backdoor che consente l'accesso remoto arbitrario.
20007	CRITICAL	9.8	SSL v2/v3 Protocol Detection	Il servizio supporta SSLv2/SSLv3, protocolli insicuri soggetti ad attacchi MITM e decrittazione.
201352	CRITICAL	10.0	Canonical Ubuntu Linux SEoL (8.04.x)	Versione EoL del sistema operativo senza aggiornamenti di sicurezza disponibili.
32314	CRITICAL	10.0	Debian OpenSSH/OpenSSL RNG Weakness	Bug critico nella libreria OpenSSL di Debian: chiavi crittografiche prevedibili.
32321	CRITICAL	10.0	Debian OpenSSH/OpenSSL RNG Weakness (SSL check)	Verifica lato SSL dello stesso bug RNG, esposizione crittografica grave.
61708	CRITICAL	10.0	VNC Server 'password' Password	Server VNC configurato con password predefinita, compromissione immediata possibile.
134862	HIGH	9.8	Apache Tomcat Ghostcat (AJP Connector Injection)	Vulnerabilità che consente l'accesso arbitrario a file e l'esecuzione di codice tramite AJP.
136769	MEDIUM	8.6	ISC BIND Service Downgrade/Reflected DoS	Possibilità di degradare o bloccare il servizio DNS con richieste malformate.
42256	MEDIUM	7.5	NFS Shares World Readable	Condivisioni NFS accessibili a tutti, perdita di riservatezza dati.
42873	MEDIUM	7.5	SSL Medium Strength Cipher Suites (SWEET32)	Supporto a cifrari a 64 bit, vulnerabili a collisioni e decrittazione del traffico.

Remediation summary

Bind Shell Backdoor Detection → Isolare immediatamente la macchina, rimuovere la backdoor, reinstallare da immagine sicura, cambiare tutte le credenziali.

SSL v2/v3 Protocol Detection → Disabilitare SSLv2 e SSLv3 nei servizi, abilitare solo TLS 1.2 o TLS 1.3.

Canonical Ubuntu Linux SEoL 8.04.x → Aggiornare il sistema a una versione supportata (LTS recente), migrare servizi e configurazioni.

Debian OpenSSH/OpenSSL RNG Weakness → Aggiornare OpenSSL/OpenSSH con versioni patchate; rigenerare tutte le chiavi crittografiche generate con la versione vulnerabile.

Debian OpenSSH/OpenSSL RNG Weakness – SSL Check → Stesso intervento del punto 4: aggiornamento e rigenerazione chiavi SSL/TLS.

VNC Server 'password' Password → Cambiare subito la password VNC con una robusta; valutare l'uso di autenticazione centralizzata o disabilitare VNC se non necessario.

Apache Tomcat Ghostcat → Aggiornare Tomcat a versione corretta; disabilitare AJP Connector se non usato; limitare accesso via firewall.

ISC BIND Service Downgrade/Reflected DoS → Aggiornare BIND all'ultima versione stabile; applicare rate-limiting e protezioni DoS lato firewall.

NFS Shares World Readable → Limitare l'accesso NFS a host autorizzati; configurare i permessi corretti nei file /etc/exports; usare autenticazione e cifratura.

SSL SWEET32 → Disabilitare cifrari a 64 bit (3DES, Blowfish); consentire solo suite moderne AES-GCM con TLS 1.2/1.3.